记一次渗透测试#信息收集

（子域名+历史请求）

目　录

一、　资产发现.....1

二、　漏洞发现.....3

文档摘要

文档编号	
文档名称	记一次渗透测试#信息收集(子域名+历史请求)
文档版本	V1.0
文档作者	
参与编写	
文档审核	
文档分类标识	
文档状态	☐草案 ☐修订中 ☑试用 ☐正式发布 ☐废止
首次编写日期	
文档属性	☐内部保密 ☑内部公开 ☐外部公开
发布范围	

一、 资产发现

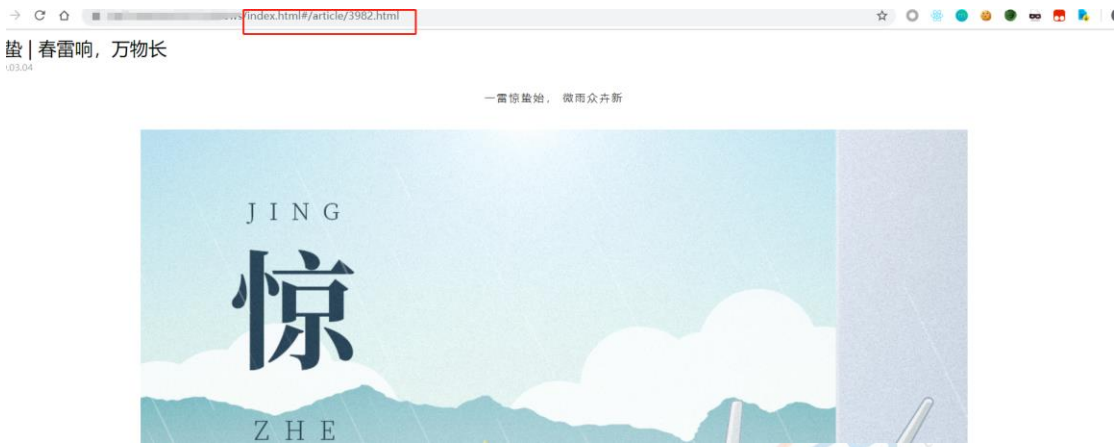
子域名收集 ---> 查看子域名
某个域名打开，是如下页面

通过点击下方功能按钮

发现，资讯跳转页面似乎有戏

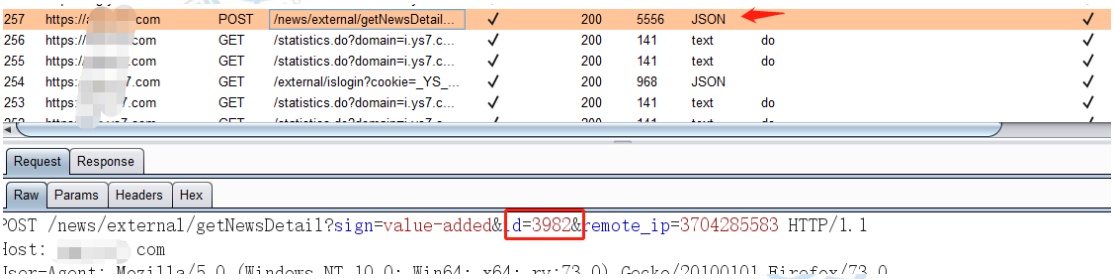
鼠标停留在在相关元素上方，查看下方 url 地址
似乎不是一个静态网页，点击

单纯的看网页地址，似乎没啥问题

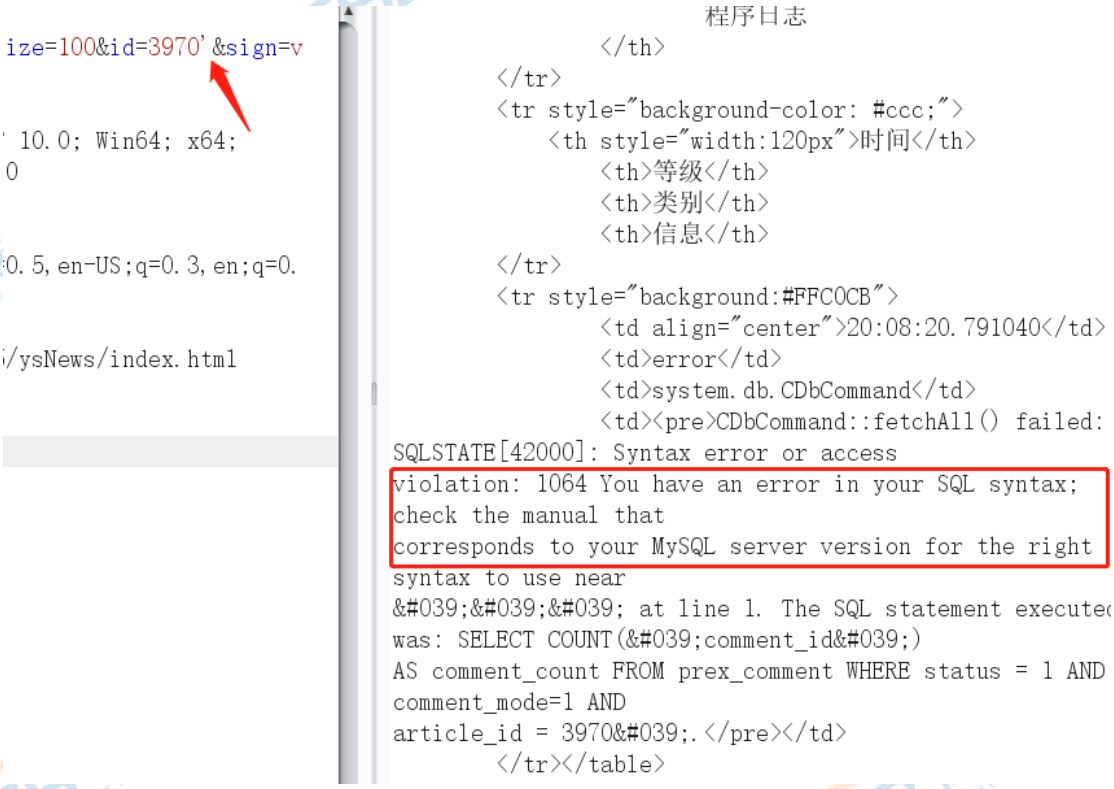

index.html#/article/3982.html
蛰 | 春雷响，万物长
一雷惊蛰始， 微雨众卉新
JING
惊
ZHE

二、 漏洞发现

习惯性的看 burp 历史包，发现有个 json 包可疑



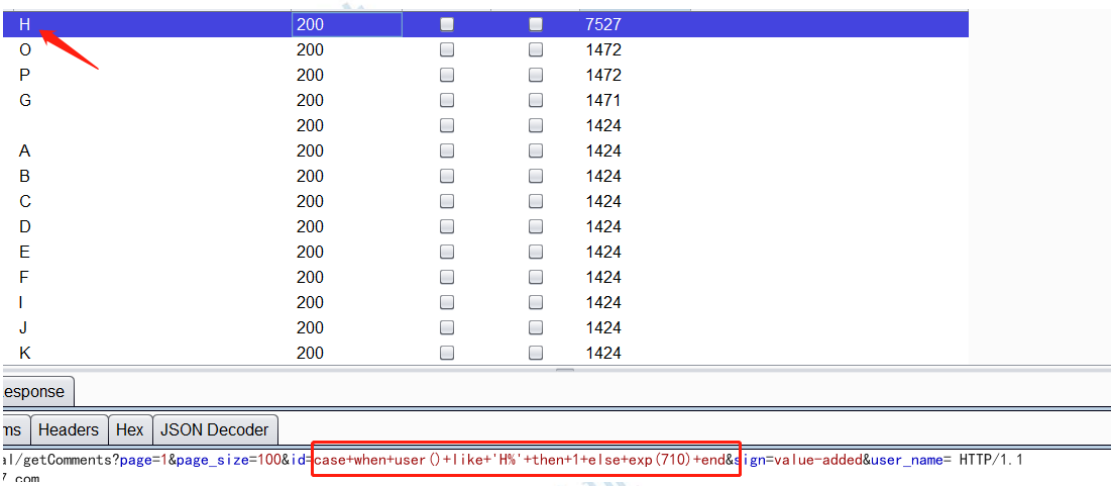
把这个 http 请求丢到 burp 重放模块，开始测试
加单引号
发现返回报错信息



测试 poc (利用条件语句，盲注的方式)
把 id 参数数字删除，使用
case+when+'1'='1'+then+1+else+exp(710)+end
条件为真或为假时，请求返回长度不同

跑用户名 poc：

case+when+user()+like+'H%'+then+1+else+exp(710)+end



用户名首位为 ： H

最后得到用户名为：'H****'